Préconisations techniques ANSSI

REDACTEUR	VERSION	DATE	NATURE DES MODIFICATIONS
Beneteau Lucas	1.0	21/05/2025	Création du document

Ce document a pour but de fournir trois préconisations techniques concernant la sécurisation du réseau de la société Impactinfluence en s'appuyant sur les recommandations de l'ANSSI et son référentiel « Recommandations relatives à l'administration sécurisée des systèmes d'information ».

1) Utilisation de protocoles sécurisés pour les flux d'administration

Les communications d'administration doivent obligatoirement utiliser des protocoles sécurisés, comme **SSH** pour les accès à distance en ligne de commande et **TLS** pour les interfaces web ou services nécessitant du chiffrement.

Les protocoles non sécurisés (Telnet, HTTP, FTP) doivent être désactivés ou bloqués.

L'administration à distance des équipements réseau (routeurs, commutateurs, etc.) se fera exclusivement via **SSH**, avec désactivation systématique de **Telnet**.
Seules les versions récentes et sécurisées des protocoles doivent être autorisées (ex. : SSHv2, TLS 1.2 ou 1.3).

Enfin, toutes les connexions d'administration doivent être journalisées (identité, IP source, date/heure, actions critiques) pour assurer la traçabilité.

2) Identification, authentification et droits d'administration

Utiliser des comptes d'administration dédiés :
L'administrateur doit disposer d'un ou plusieurs comptes d'administration dédiés, distincts de son compte utilisateur. Les secrets d'authentification doivent être différents suivant le compte utilisé.

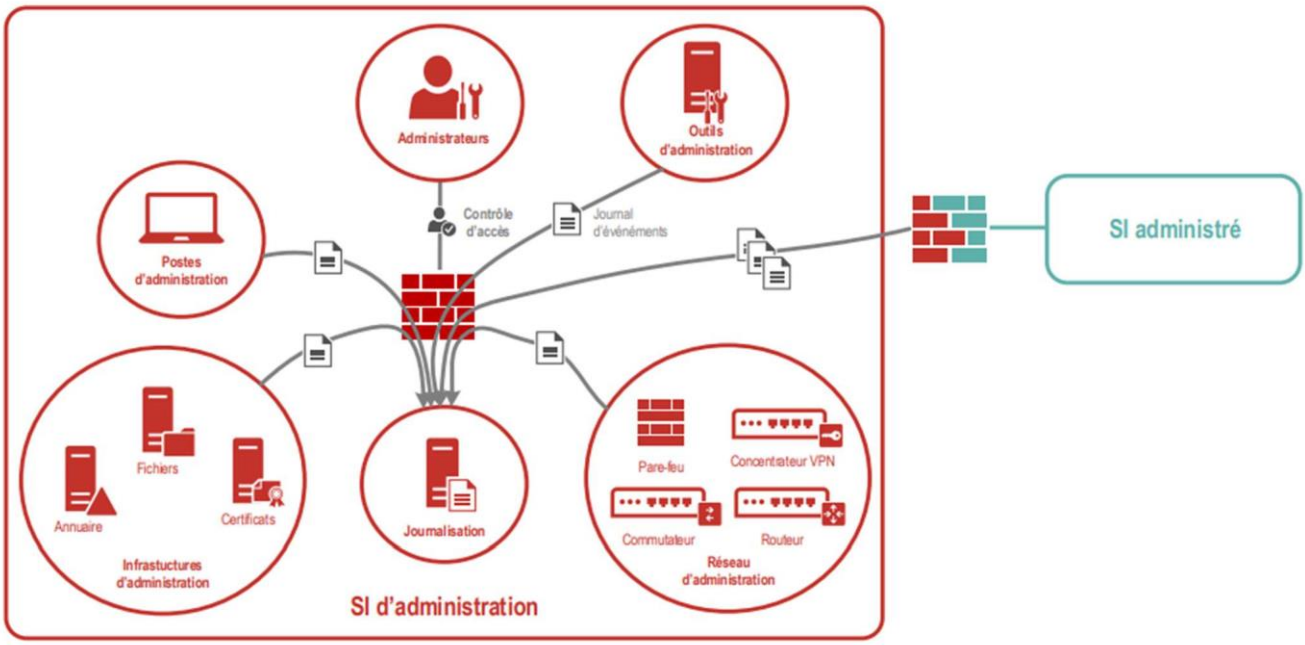
Réserver les comptes d'administration aux seules actions d'administration :
Les comptes d'administration doivent être utilisés exclusivement pour des actions d'administration. En particulier, aucun compte d'administration ne doit être utilisé pour des actions bureautiques.

Utiliser par défaut des comptes d'administration individuels :
Des comptes d'administration individuels doivent être attribués à chaque administrateur. Les comptes natifs d'administration ne doivent pas être utilisés pour les actions courantes d'administration et les secrets associés ne doivent être accessibles qu'à un nombre très restreint de personnes.

Journaliser les événements liés aux comptes d'administration :
Les mécanismes d'audit des événements concernant les comptes d'administration doivent être mis en œuvre. En particulier, les journaux suivants doivent être activés :

i. Ouvertures et fermetures de session ;
ii. Échecs d'authentification et verrouillage des comptes ;
iii. Gestion des comptes ;
iv. Modification des configurations.

3) Journalisation et supervision de la sécurité

La journalisation des événements techniques, dont ceux liés à la sécurité, et leur analyse régulière permettent de détecter une éventuelle compromission du SI. L'archivage de ces informations permet les investigations numériques pour comprendre comment une intrusion a été possible.

L'architecture devra prévoir la transmission des journaux d'événements de manière centralisée, depuis les équipements vers les services de journalisation.